

CYNA

Cahier de recettes

Plan de tests et de validation

Adrien CACHOUX, Romain CANER, Ethan MIRBEAU

SUP DE VINCI - BSI | Projet fil rouge | Version 1.0

Solutions de cybersécurité SaaS — SOC · EDR · XDR

Sommaire

1. Tests unitaires automatisés
2. Tests d'intégration — parcours fonctionnels
3. Matrice de tests de sécurité
4. Tests d'accessibilité (WCAG 2.1 AA)
5. Synthèse de recette

1. Tests unitaires automatisés

1.1 Site web — PHPUnit

Classe testée	Fichier de test	Cas couverts
Core\Totp	tests/Unit/TotpTest.php	Génération de secret (longueur, alphabet Base32), acceptation du code courant, tolérance +/-1 période, rejet hors fenêtre, rejet des codes mal formés, URI d'enrôlement
Core\Validator	tests/Unit/ValidatorTest.php	required, email, min / max, numeric, confirmed, in, robustesse du mot de passe, libellés personnalisés
Core\Paginator	tests/Unit/PaginatorTest.php	Calcul dernière page/offset, bornage des pages, liste vide, perPage minimal, conservation des paramètres d'URL
Core\Csrf	tests/Unit/CsrfTest.php	Format du jeton, stabilité dans la session, acceptation du bon jeton, rejet des jetons erroné/null/absent
Services\Cart	tests/Unit/CartTest.php	Ajout/incrément, lignes distinctes par périodicité, normalisation de périodicité, mise à jour et suppression de quantité, vidage
Helpers globaux	tests/Unit/HelpersTest.php	Mise en forme monétaire, génération de slug, échappement anti-XSS

Exécution :

```
cd Cyna
composer install
composer test
```

1.2 Application Java — JUnit 5

Classe testée	Fichier de test	Cas couverts
security.CredentialUtils	src/test/java/.../CredentialUtilsTest.java	Vérification bcrypt (mot de passe correct/incorrect), normalisation des hachages PHP \$2y / \$2b, entrées nulles/vides, hachage mal formé, acceptation/rejet du code TOTP, secret 2FA absent

Exécution :

mvn test

2. Tests d'intégration — parcours fonctionnels

CU-01 — Inscription et confirmation par e-mail

#	Action	Résultat attendu	Statut
1	Ouvrir / inscription , saisir nom, e-mail, mot de passe faible (abc)	Message d'erreur : le mot de passe doit contenir 8 caractères, maj/min/chiffre/spécial	[]
2	Saisir un mot de passe conforme (Client@1234) et valider	Compte créé, e-mail de confirmation envoyé, message de succès	[]
3	Cliquer sur le lien de confirmation reçu	Compte activé, connexion automatique, redirection tableau de bord	[]
4	Tenter de se connecter avant confirmation	Message invitant à confirmer l'e-mail	[]

CU-02 — Connexion et « mot de passe oublié »

#	Action	Résultat attendu	Statut
1	Connexion avec un mauvais mot de passe	Erreur + lien « Mot de passe oublié » proposé	[]
2	Demander la réinitialisation	E-mail avec lien sécurisé valable 24 h	[]
3	Suivre le lien, définir un nouveau mot de passe conforme	Mot de passe mis à jour, ancien lien invalidé	[]
4	Cocher « Se souvenir de moi » puis fermer/ rouvrir le navigateur	Session conservée	[]

CU-03 — Catalogue, recherche et fiche produit

#	Action	Résultat attendu	Statut
1	Ouvrir une catégorie	Produits triés (disponibles/priorité), épuisés en fin de liste avec mention textuelle	[]
2	Rechercher un terme exact (ex. « EDR »)	Correspondances exactes en tête, puis « commence par », puis « contient »	[]
3	Appliquer les facettes (prix min/max, catégorie, disponibilité)	Résultats filtrés, mise à jour cohérente	[]
4	Ouvrir une fiche produit	Carrousel, description, specs, prix mensuel/ annuel, services similaires, CTA	[]

CU-04 — Panier et tunnel de commande (Stripe)

#	Action	Résultat attendu	Statut
1	Ajouter un service au panier en tant qu'invité	Panier accessible, total calculé en temps réel	[]
2	Ajouter un service indisponible	Ligne marquée « Indisponible », checkout bloqué	[]
3	Passer à la caisse, se connecter/ continuer en invité	Étapes : adresse -> paiement -> confirmation	[]
4	Payer avec la carte de test Stripe 4242 4242 4242 4242	Paiement accepté, commande créée, e-mail envoyé	[]
5	Télécharger la facture PDF depuis la confirmation	Facture PDF conforme (montants, adresse, 4 derniers chiffres)	[]

CU-05 — Espace compte

#	Action	Résultat attendu	Statut
1	Modifier le profil et l'e-mail	E-mail de validation envoyé à la nouvelle adresse	[]
2	Changer le mot de passe (avec mot de passe actuel)	Refus si mot de passe actuel erroné	[]
3	Ajouter/modifier/supprimer une adresse, définir par défaut	Carnet d'adresses à jour	[]
4	Renouveler puis résilier un abonnement	Statut mis à jour, confirmation affichée	[]
5	Consulter l'historique groupé par année, ouvrir une commande	Détail complet + lien facture PDF	[]

CU-06 — Back-office (administrateur)

#	Action	Résultat attendu	Statut
1	Se connecter avec <code>admin@cyna-it.fr</code> + 2FA	Accès refusé sans code TOTP valide	[]
2	Créer/éditer/supprimer un produit, suppression multiple	Liste triable mise à jour	[]
3	Modifier le carrousel et le texte de la page d'accueil	Front mis à jour	[]
4	Changer le statut d'une commande	Statut reflété côté client	[]
5	Consulter le tableau de bord	Histogramme des ventes, camembert par catégorie, paniers moyens	[]

CU-07 — Application Java Swing

#	Action	Résultat attendu	Statut
1	Se connecter avec un compte admin (bcrypt + TOTP)	Accès accordé uniquement si mot de passe et code 2FA valides	[]
2	Consulter/gérer les produits et les commandes	Données synchronisées avec la base MySQL du site web	[]
3	Suivre l'état d'installation d'une commande payée	Statut mis à jour en base	[]

3. Matrice de tests de sécurité

Répond au KPI « 100 % des failles cibles couvertes par un test documenté » (note de cadrage §2.5, §5.3).

Réf	Faible cible	Scénario de test	Résultat attendu	Auto/Manuel
SEC-01	Injection SQL	Saisir <code>' OR 1=1 --</code> dans la connexion et la recherche	Aucune fuite ; requêtes préparées neutralisent l'entrée	Manuel + revue
SEC-02	XSS stocké	Soumettre <code><script>alert(1)</script></code> dans le formulaire de contact	Contenu échappé à l'affichage back-office, script non exécuté	Manuel + Help
SEC-03	XSS réfléchi	Injecter un script dans un paramètre de recherche	Sortie échappée (<code>e()</code>)	Manuel
SEC-04	CSRF	Rejouer un POST sans/ avec un <code>_token</code> invalide	Requête rejetée (403)	Manuel + Csrf
SEC-05	Contrôle d'accès	Accéder à <code>/admin</code> sans être authentifié admin	Redirection vers la connexion	Manuel
SEC-06	Élévation de privilège	Accéder à <code>/admin</code> avec un compte client standard	Accès refusé (middleware <code>RequireAdmin</code>)	Manuel
SEC-07	Force du mot de passe	Créer un compte avec un mot de passe faible	Refus (règle <code>password</code>)	Auto (Validato)

Réf	Faible cible	Scénario de test	Résultat attendu	Auto/Manuel
SEC-08	2FA	Se connecter au back-office avec un code TOTP erroné/expiré	Accès refusé	Auto (<code>TotpTest</code> <code>CredentialUtili</code>)
SEC-09	Stockage des secrets	Vérifier en base que les mots de passe sont hachés bcrypt	Aucun mot de passe en clair	Manuel (inspect)
SEC-10	Données de carte	Vérifier qu'aucun PAN complet n'est stocké	Seuls token Stripe + 4 derniers chiffres présents	Manuel (inspect)
SEC-11	Sessions	Vérifier <code>httponly</code> / <code>secure</code> / <code>samesite</code> et régénération d'ID après login	Cookie conforme, ID régénéré	Manuel (DevTools)
SEC-12	Jetons e-mail	Réutiliser un lien de réinitialisation déjà consommé ou expiré	Lien invalide	Manuel
SEC-13	Clickjacking	Charger le site dans une <code><iframe></code> externe	Chargement bloqué (<code>X-Frame-Options</code>)	Manuel
SEC-14	En-têtes de sécurité	Vérifier CSP, <code>X-Content-Type-Options</code>	En-têtes présents	Manuel (curl -I)

4. Tests d'accessibilité (WCAG 2.1 AA)

Réf	Vérification	Outil	Cible	Statut
A11Y-01	Score accessibilité	Lighthouse	>= 80/100 sur accueil, catalogue, produit, checkout, compte	[]
A11Y-02	Navigation clavier complète	Manuel	Parcours d'achat sans souris, focus visible	[]
A11Y-03	Lecteur d'écran	NVDA / VoiceOver	Formulaires inscription/ connexion/ checkout	[]
A11Y-04	Contrastes	Lighthouse / DevTools	Ratio >= 4,5:1	[]

Réf	Vérification	Outil	Cible	Statut
A11Y-05	Information non portée par la seule couleur	Manuel	État « épuisé » signalé aussi par texte	[]

5. Synthèse de recette

Domaine	Cas total	[OK]	[!]	[X]	[]
Unitaires automatisés	2 suites				
Fonctionnels (CU-01 -> CU-07)	28				
Sécurité (SEC-01 -> SEC-14)	14				
Accessibilité (A11Y-01 -> A11Y-05)	5				

Ce tableau est à compléter lors de la campagne de recette finale (Bloc 3). Un défaut critique ([X]) bloque la livraison, conformément au KPI « 0 bug bloquant ».